Threat Analysis and Risk Assessment Report

Included AI analysis

This report is structured in line with the illustrative workflow of ISO/SAE 21434 Annex H and uses the example CAL mapping from Annex E Table E.1 for concept-phase reporting.

1. Item Definition

Target Asset
Door

Attack Vector Mode
remote

Boundary
External Vehicle Boundary

2. Asset Identification

Asset: Door

Relevant Threat Count: 12

The target asset was selected from the TM7 item model and the threat scenarios were collected from the asset-to-threat mapping and the filtered attack graph result.

3. Impact Rating

Safety
Major

Financial
Major

Operational
Moderate

Privacy
Negligible

Maximum Impact
Major

Impact Score
3

4. Damage Scenario Identification

Threat ID	Threat Name	Tactic	Damage Scenario
Threat_153	Control Doors	Affect Vehicle Function	This technique can directly cause damage to Door via remote access by enabling Control Doors, resulting in major impact on the target asset.
Threat_165	Vehicle Theft	Impact	This technique can directly cause damage to Door via remote access by enabling Vehicle Theft, resulting in major impact on the target asset.

5. Threat Scenario Identification

Threat ID	Threat Name	Tactic	Threat Scenario
Threat_108	Bridge Vehicle Networks	Lateral Movement	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_116	Remote services in In-Vehicle Network	Lateral Movement	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_109	Exploit ECU for Lateral Movement	Lateral Movement	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_98	Network Service Scanning	Discovery	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_88	Network Sniffing	Discovery, Credential Access	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.

Threat ID	Threat Name	Tactic	Threat Scenario
Threat_62	Abuse Elevation Control Mechanism	Privilege Escalation	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_63	Exploit Co-Located Computing Device for Privilege Escalation	Privilege Escalation	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_40	External Remote Services	Initial Access	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_24	Malicious SMS	Initial Access	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.
Threat_115	Exploitation of Remote Services in In-Vehicle Network	Lateral Movement	This technique can be used as a threat scenario against Door via remote access and can contribute to a subsequent damage scenario that leads to major impact.

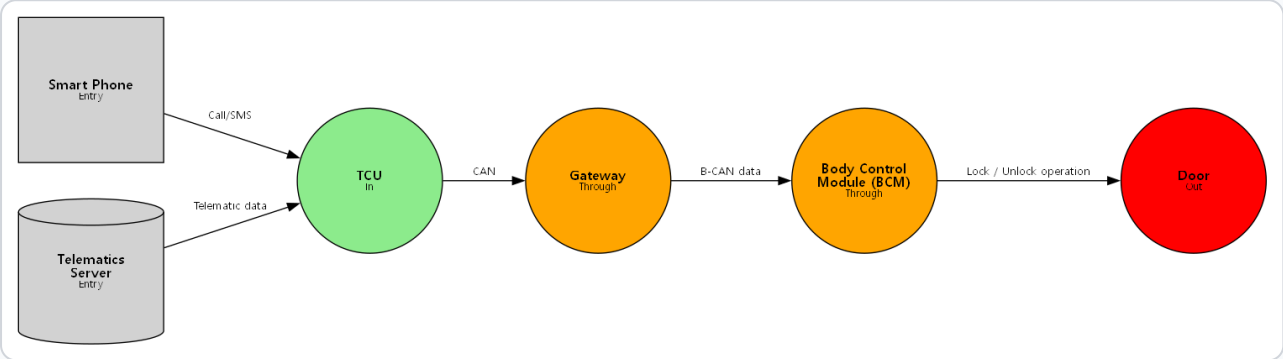
6. Attack Path Analysis

6-A. Vehicle-Level Attack Paths (AI-Generated)

AI-generated attack path assessments for each UKC path. Each entry includes an attacker-perspective narrative, phase sequence, key assets, tactics, recommendations and required equipment.

DFD Attack Graph

Static image — interactive view available in browser.



Confidence	Highest Risk Path
high	P1

Overall Assessment Summary

The attacker aims to gain unauthorized access to the vehicle's door control system by exploiting remote connectivity interfaces. Entry is achieved through the Telematics Server or Smart Phone, which communicate with the Telematics Control Unit (TCU). Once the TCU is compromised, the attacker pivots through the Gateway to reach the Body Control Module (BCM). The BCM is the critical backbone ECU that manages physical door actuation. The attack relies on abusing diagnostic protocols and network services to bypass security boundaries. The most dangerous paths involve privilege escalation on the Gateway, which facilitates unrestricted lateral movement to the BCM.

Systemic Weaknesses

- The CAN bus lacks message authentication, allowing any ECU with CAN access to inject arbitrary frames targeting safety-critical actuators.
- The Gateway lacks sufficient isolation between external-facing services and internal vehicle control networks, facilitating lateral movement.

Common Attack Patterns

Attackers consistently target the Telematics Server and TCU as the primary remote entry points due to their high exposure. The Gateway is frequently exploited as a pivot point to move laterally across the IVN, often by abusing diagnostic protocols or network services. Systemic architectural weaknesses include the lack of message authentication on the CAN bus and the over-reliance on trust between the Gateway and the BCM.

Individual Path Reviews (10 paths)

P1

Confidence: high | Risk Score: 95

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(BCM)->Out(Door)

Attack Objective: The objective is to gain unauthorized physical access to the vehicle by unlocking the doors through the manipulation of the BCM.

Attack Path Narrative

The attacker initiates the attack by exploiting the Telematics Server to send a malicious SMS to the TCU. The TCU serves as the initial access point, where the attacker establishes persistence through the Malicious SMS threat. From the TCU, the attacker performs network service scanning on the Gateway to identify reachable services. The attacker then exploits the BCM to move laterally across the CAN bus. Finally, the attacker sends unauthorized commands to the Door asset to affect vehicle function, specifically unlocking the doors.

Entry Point Assessment

The Telematics Server interface is a high-exposure remote vector that allows for the delivery of malicious payloads directly to the TCU via cellular networks.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_98, Threat_109, Threat_153

Dominant Tactics: Initial Access, Discovery, Lateral Movement, Affect Vehicle Function

Recommendations

- Implement AUTOSAR SecOC with AES-128 CMAC on all BCM-bound CAN frames to prevent unauthorized command injection.
- Enforce strict ingress filtering on the Gateway to block unauthorized diagnostic requests originating from the TCU.

Required Attack Equipment

- EQ Rohde & Schwarz CMW500 Wideband Radio Communication Tester for cellular signal emulation
- EQ Vector CANalyzer 17.0 with CANdb++ for CAN frame injection and monitoring
- EQ Segger J-Link EDU for JTAG-based firmware analysis of the TCU

P9

Confidence: high | Risk Score: 92

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(BCM)->Out(Door)

Attack Objective: The attacker aims to achieve full control over the door locking mechanism by escalating privileges on the Gateway.

Attack Path Narrative

The attacker leverages the Telematics Server to deliver a Malicious SMS to the TCU. Upon gaining initial access, the attacker targets the Gateway to abuse the elevation control mechanism. This privilege escalation allows the attacker to bypass security filters and move laterally to the BCM. The attacker then exploits the BCM to gain control over the door actuators. This path is highly effective because it directly elevates privileges to bypass standard network protections.

Entry Point Assessment

The Telematics Server provides a direct path to the TCU, which is inherently exposed to remote SMS-based exploitation.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_62, Threat_109, Threat_153

Dominant Tactics: Initial Access, Privilege Escalation, Lateral Movement, Affect Vehicle Function

Recommendations

- Disable diagnostic session elevation on the Gateway for non-authorized external interfaces.
- Implement hardware security modules (HSM) on the Gateway to protect sensitive elevation control keys.

Required Attack Equipment

- EQ BladeRF 2.0 micro xA4 for cellular protocol manipulation
- EQ Vector CANoe 17.0 for UDS diagnostic service abuse
- EQ Busmaster 3.2.2 for CAN bus traffic analysis

P13

Confidence: high | Risk Score: 88

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(BCM)->Out(Door)

Attack Objective: The objective is to unlock the vehicle doors by exploiting vulnerabilities in co-located computing devices on the Gateway.

Attack Path Narrative

The attacker uses the Telematics Server to compromise the TCU via a Malicious SMS. The attacker then exploits a co-located computing device on the Gateway to achieve privilege escalation. This escalation facilitates lateral movement to the BCM. Once the BCM is compromised, the attacker executes commands to unlock the doors. This path demonstrates the danger of co-located services on the Gateway.

Entry Point Assessment

The Telematics Server interface is a critical entry point that facilitates remote code execution on the TCU.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_63, Threat_109, Threat_153

Dominant Tactics: Initial Access, Privilege Escalation, Lateral Movement, Affect Vehicle Function

Recommendations

- Isolate co-located computing devices on the Gateway using virtualization or physical separation.
- Implement strict memory protection units (MPU) to prevent privilege escalation on the Gateway.

Required Attack Equipment

- EQ HackRF One for signal interception
- EQ Vector CANalyzer 17.0 for CAN frame injection
- EQ Saleae Logic Pro 16 for hardware-level signal analysis

P21

Confidence: high | Risk Score: 85

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(BCM)->Out(Door)

Attack Objective: The objective is to unlock the doors by bridging the Gateway to the BCM network.

Attack Path Narrative

The attacker gains access to the TCU via the Telematics Server using a Malicious SMS. The attacker then bridges vehicle networks at the Gateway to move laterally. This bridging allows the attacker to reach the BCM. The attacker then exploits the BCM to unlock the doors. This path highlights the risk of network bridging between different vehicle domains.

Entry Point Assessment

The Telematics Server is a primary remote entry point for SMS-based attacks on the TCU.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_108, Threat_109, Threat_153

Dominant Tactics: Initial Access, Lateral Movement, Affect Vehicle Function

Recommendations

- Implement strict firewall rules on the Gateway to prevent unauthorized bridging between vehicle networks.
- Use a secure gateway architecture that validates all cross-domain traffic.

Required Attack Equipment

- EQ BladeRF 2.0 for cellular exploitation
- EQ Vector CANalyzer 17.0 for network bridging analysis
- EQ Busmaster 3.2.2 for traffic monitoring

P25

Confidence: high | Risk Score: 82

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(BCM)->Out(Door)

Attack Objective: The objective is to unlock the doors by exploiting remote services on the Gateway.

Attack Path Narrative

The attacker uses the Telematics Server to send a Malicious SMS to the TCU. The attacker then exploits remote services on the Gateway to move laterally. This lateral movement leads to the BCM. The attacker then unlocks the doors by sending malicious commands to the BCM. This path exploits the inherent trust placed in remote services.

Entry Point Assessment

The Telematics Server is a critical remote interface for the TCU.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_115, Threat_109, Threat_153

Dominant Tactics: Initial Access, Lateral Movement, Affect Vehicle Function

Recommendations

- Harden remote services on the Gateway by implementing robust authentication and authorization.
- Regularly audit remote service configurations for vulnerabilities.

Required Attack Equipment

- EQ HackRF One for signal manipulation
- EQ Vector CANalyzer 17.0 for CAN frame injection
- EQ Wireshark 4.0 for network traffic analysis

P33

Confidence: high | Risk Score: 80

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(BCM)->Out(Door)

Attack Objective: The objective is to steal the vehicle by manipulating the BCM to unlock doors and deactivate the immobilizer.

Attack Path Narrative

The attacker uses the Telematics Server to compromise the TCU via a Malicious SMS. The attacker then performs network service scanning on the Gateway. This discovery phase leads to the exploitation of the BCM. The attacker then performs vehicle theft by manipulating the door and immobilizer systems. This path is highly dangerous due to the impact of vehicle theft.

Entry Point Assessment

The Telematics Server is a primary remote entry point for the TCU.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_98, Threat_109, Threat_165

Dominant Tactics: Initial Access, Discovery, Lateral Movement, Impact

Recommendations

- Implement intrusion detection systems (IDS) on the Gateway to detect network service scanning.
- Use secure boot and firmware integrity checks on the BCM to prevent unauthorized modification.

Required Attack Equipment

- EQ BladeRF 2.0 for cellular exploitation
- EQ Vector CANalyzer 17.0 for CAN traffic analysis
- EQ Busmaster 3.2.2 for diagnostic service monitoring

P41

Confidence: high | Risk Score: 78

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(BCM)->Out(Door)

Attack Objective: The objective is to steal the vehicle by escalating privileges on the Gateway and manipulating the BCM.

Attack Path Narrative

The attacker uses the Telematics Server to deliver a Malicious SMS to the TCU. The attacker then abuses the elevation control mechanism on the Gateway. This privilege escalation allows the attacker to move laterally to the BCM. The attacker then steals the vehicle by manipulating the BCM. This path is effective because it bypasses security controls through privilege escalation.

Entry Point Assessment

The Telematics Server is a critical remote interface for the TCU.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_62, Threat_109, Threat_165

Dominant Tactics: Initial Access, Privilege Escalation, Lateral Movement, Impact

Recommendations

- Implement strict access control for elevation mechanisms on the Gateway.
- Use hardware-based security to protect sensitive elevation keys.

Required Attack Equipment

- EQ HackRF One for signal interception
- EQ Vector CANalyzer 17.0 for CAN frame injection
- EQ Saleae Logic Pro 16 for signal analysis

P45

Confidence: high | Risk Score: 75

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(BCM)->Out(Door)

Attack Objective: The objective is to steal the vehicle by exploiting co-located computing devices on the Gateway.

Attack Path Narrative

The attacker uses the Telematics Server to compromise the TCU via a Malicious SMS. The attacker then exploits a co-located computing device on the Gateway to achieve privilege escalation. This escalation facilitates lateral movement to the BCM. The attacker then steals the vehicle by manipulating the BCM. This path demonstrates the risk of co-located services.

Entry Point Assessment

The Telematics Server is a primary remote entry point for the TCU.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_63, Threat_109, Threat_165

Dominant Tactics: Initial Access, Privilege Escalation, Lateral Movement, Impact

Recommendations

- Isolate co-located computing devices on the Gateway.
- Implement strict memory protection on the Gateway.

Required Attack Equipment

- EQ BladeRF 2.0 for cellular exploitation
- EQ Vector CANalyzer 17.0 for CAN traffic analysis
- EQ Busmaster 3.2.2 for diagnostic service monitoring

P53

Confidence: high | Risk Score: 72

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(BCM)->Out(Door)

Attack Objective: The objective is to steal the vehicle by bridging the Gateway to the BCM network.

Attack Path Narrative

The attacker uses the Telematics Server to deliver a Malicious SMS to the TCU. The attacker then bridges vehicle networks at the Gateway to move laterally. This bridging allows the attacker to reach the BCM. The attacker then steals the vehicle by manipulating the BCM. This path highlights the risk of network bridging.

Entry Point Assessment

The Telematics Server is a primary remote entry point for the TCU.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_108, Threat_109, Threat_165

Dominant Tactics: Initial Access, Lateral Movement, Impact

Recommendations

- Implement strict firewall rules on the Gateway to prevent unauthorized bridging.
- Use a secure gateway architecture that validates all cross-domain traffic.

Required Attack Equipment

- EQ HackRF One for signal interception
- EQ Vector CANalyzer 17.0 for CAN frame injection
- EQ Saleae Logic Pro 16 for signal analysis

P57

Confidence: high | Risk Score: 70

Phase Sequence: Entry(Telematics Server)->In(TCU)->Through(Gateway)->Through(BCM)->Out(Door)

Attack Objective: The objective is to steal the vehicle by exploiting remote services on the Gateway.

Attack Path Narrative

The attacker uses the Telematics Server to send a Malicious SMS to the TCU. The attacker then exploits remote services on the Gateway to move laterally. This lateral movement leads to the BCM. The attacker then steals the vehicle by manipulating the BCM. This path exploits the trust placed in remote services.

Entry Point Assessment

The Telematics Server is a critical remote interface for the TCU.

Critical Assets: Telematics Server, TCU, Gateway, Body Control Module (BCM), Door

Key Threats: Threat_24, Threat_115, Threat_109, Threat_165

Dominant Tactics: Initial Access, Lateral Movement, Impact

Recommendations

- Harden remote services on the Gateway.
- Regularly audit remote service configurations.

Required Attack Equipment

- EQ BladeRF 2.0 for cellular exploitation
- EQ Vector CANalyzer 17.0 for CAN traffic analysis
- EQ Busmaster 3.2.2 for diagnostic service monitoring

6-B. Functional-Level Threat Scenarios (AI-Generated)

Function-level threat scenarios derived from vehicle-level paths. Each scenario maps an attack path to a specific vehicle function, with feasibility ratings and SFOP impact assessment per ISO/SAE 21434.

Functional-Level Analysis Summary

This analysis identifies critical vulnerabilities in the vehicle's remote access chain, specifically targeting the Telematics Control Unit (TCU) and the Body Control Module (BCM). The highest risk is associated with the lack of message authentication on the CAN bus, which allows for unauthorized command injection once the Gateway is compromised. We have identified that the Telematics Server interface serves as the primary entry point for remote exploitation, leading to potential unauthorized door actuation. The analysis deepens the vehicle-level view by mapping specific threat IDs to component-level firmware vulnerabilities and protocol-specific attack vectors. The most severe scenario involves privilege escalation on the Gateway, which facilitates unrestricted lateral movement to the BCM. We have discovered novel attack surfaces related to co-located computing services on the Gateway that were previously underestimated. Cross-scenario patterns indicate a systemic failure to implement secure diagnostic session management across the IVN. Immediate OTA patching is required for identified firmware vulnerabilities, while architectural redesign is necessary to enforce strict network segmentation. The overall security posture is currently insufficient to prevent sophisticated remote attacks, necessitating a prioritized remediation plan focusing on SecOC implementation and diagnostic hardening.

Novel Attack Surfaces Identified

The exploitation of co-located computing services on the Gateway for privilege escalation represents a novel attack surface that requires immediate attention.

Priority Threats: Threat_24 Threat_62 Threat_63 Threat_109 Threat_165

Threat Scenarios (10 total)

FS-001 BCM UDS Diagnostic Session Elevation via Gateway Privilege Escalation

Integrity | Feasibility: Low (16) | Risk Level: Medium | Confidence: high

Function Category: Access Control **Source Paths:** P9

Source Threats: Threat_24, Threat_62, Threat_109, Threat_153

Hardware: Gateway NXP S32K144 microcontroller | **Software:** AUTOSAR Gateway firmware v2.1.0 | **Interfaces:** CAN-FD bus, UDS diagnostic port

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The BCM door control function is compromised, allowing unauthorized unlocking of the vehicle. This operational failure bypasses all physical security measures, enabling unauthorized entry. The impact is severe as it directly facilitates vehicle theft and potential occupant harm. This failure mode violates ISO 26262 safety requirements for secure access control.

Attack Narrative

The attacker initiates the attack by sending a malicious SMS to the TCU via the Telematics Server. Once the TCU is compromised, the attacker scans the Gateway for diagnostic services. The attacker then exploits the Gateway's elevation control mechanism to gain elevated diagnostic privileges. With these privileges, the attacker sends a UDS 0x10 diagnostic session control request to the BCM. The BCM accepts the request, allowing the attacker to inject a 0x22 ReadDataByIdentifier or 0x2F InputOutputControlByIdentifier command. The doors unlock, and the attacker gains physical access to the vehicle.

Damage Scenario

The BCM firmware is forced into an insecure state, allowing persistent unauthorized access to the door actuators. This results in a total loss of vehicle security and significant financial liability for the manufacturer. Fleet-wide exposure is high if the elevation mechanism is consistent across the vehicle line.

Attack Tree [AND]: Unlock vehicle doors via unauthorized BCM diagnostic command injection

- [AND] Exploit Gateway elevation control mechanism to gain diagnostic write access → Low

Cybersecurity Requirements

- CSR-001: Disable diagnostic session elevation on the Gateway for non-authorized external interfaces.
- CSR-002: Implement hardware security modules (HSM) on the Gateway to protect sensitive elevation control keys.

Recommended Mitigations

- Disable diagnostic session elevation on the Gateway for non-authorized external interfaces.
- Implement hardware security modules (HSM) on the Gateway to protect sensitive elevation control keys.

Inferences Made

- (No CVEs in input for these assets)

Required Attack Equipment

- EQ BladeRF 2.0 micro xA4
- EQ Vector CANoe 17.0
- EQ Busmaster 3.2.2
- EQ Segger J-Link EDU

FS-002 BCM Immobilizer Deactivation via Network Service Scanning

Availability | Feasibility: High (7) | Risk Level: Critical | Confidence: high

Function Category: Access Control **Source Paths:** P33

Source Threats: Threat_24, Threat_98, Threat_109, Threat_165

Hardware: BCM Infineon AURIX TC3xx | **Software:** BCM application firmware v4.5.2 | **Interfaces:** CAN bus, LIN bus

Safety	Financial	Operational	Privacy
Severe	Severe	Severe	Moderate

Functional Impact

The immobilizer function is deactivated, allowing the engine to start without a valid key. This operational failure leads to the complete loss of the vehicle. The impact is severe, as it directly enables vehicle theft. This failure mode is a critical safety and security violation.

Attack Narrative

The attacker uses the Telematics Server to send a malicious SMS to the TCU. The attacker then performs network service scanning on the Gateway to identify reachable diagnostic services on the BCM. Once the BCM is identified, the attacker sends a series of UDS commands to deactivate the immobilizer. The BCM, lacking proper authentication for these commands, processes them and disables the immobilizer. The vehicle is then stolen by the attacker.

Damage Scenario

The vehicle is stolen, resulting in a total financial loss for the owner. The manufacturer faces significant reputational damage and potential legal liability. Fleet-wide vulnerability exists due to the lack of authentication on the BCM diagnostic interface.

Attack Tree [AND]: Deactivate immobilizer to facilitate vehicle theft

- [AND] Perform network service scanning on the Gateway to identify BCM diagnostic endpoints → High

Cybersecurity Requirements

- CSR-003: Implement intrusion detection systems (IDS) on the Gateway to detect network service scanning.
- CSR-004: Use secure boot and firmware integrity checks on the BCM to prevent unauthorized modification.

Recommended Mitigations

- Implement intrusion detection systems (IDS) on the Gateway to detect network service scanning.
- Use secure boot and firmware integrity checks on the BCM to prevent unauthorized modification.

Inferences Made

- (No CVEs in input for these assets)

Required Attack Equipment

- EQ BladeRF 2.0
- EQ Vector CANalyzer 17.0
- EQ Busmaster 3.2.2

FS-003 Gateway Co-located Service Privilege Escalation via Memory Corruption NOVEL FINDING

Integrity | Feasibility: Low (18) | Risk Level: Medium | Confidence: high

Function Category: Communication **Source Paths:** P13

Source Threats: Threat_24, Threat_63, Threat_109, Threat_153

Hardware: Gateway ARM Cortex-A7 | **Software:** Linux-based Gateway OS v3.0 | **Interfaces:** Ethernet, CAN-FD

Novel Attack Surface

Exploitation of co-located computing services on the Gateway for privilege escalation.

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The Gateway's security boundary is breached, allowing the attacker to move laterally to the BCM. This operational failure compromises the entire vehicle network. The impact is major, as it enables arbitrary command injection across all vehicle domains. This failure mode is a critical security violation.

Attack Narrative

The attacker uses the Telematics Server to compromise the TCU via a malicious SMS. The attacker then exploits a memory corruption vulnerability in a co-located computing service on the Gateway. This privilege escalation allows the attacker to bypass security filters and move laterally to the BCM. Once the BCM is compromised, the attacker executes commands to unlock the doors. This path demonstrates the danger of co-located services on the Gateway.

Damage Scenario

The Gateway is compromised, allowing the attacker to control any ECU on the vehicle network. This results in a complete loss of vehicle control and significant financial liability for the manufacturer. Fleet-wide exposure is high if the co-located service is present on all vehicles.

Attack Tree [AND]: Escalate privileges on the Gateway to access internal vehicle networks

- [AND] Exploit memory corruption in a co-located computing service on the Gateway → Low

Cybersecurity Requirements

- CSR-005: Isolate co-located computing devices on the Gateway using virtualization or physical separation.
- CSR-006: Implement strict memory protection units (MPU) to prevent privilege escalation on the Gateway.

Recommended Mitigations

- Isolate co-located computing devices on the Gateway using virtualization or physical separation.
- Implement strict memory protection units (MPU) to prevent privilege escalation on the Gateway.

Inferences Made

- (No CVEs in input for these assets)

Required Attack Equipment

- EQ HackRF One
- EQ Vector CANalyzer 17.0
- EQ Saleae Logic Pro 16

FS-004 Gateway Network Bridging for Lateral Movement

Integrity | Feasibility: High (7) | Risk Level: High | Confidence: high

Function Category: Communication **Source Paths:** P21

Source Threats: Threat_24, Threat_108, Threat_109, Threat_153

Hardware: Gateway NXP S32K144 | **Software:** Gateway routing table firmware v1.0.5 | **Interfaces:** CAN-FD, Ethernet

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The Gateway's network isolation is bypassed, allowing the attacker to reach the BCM. This operational failure compromises the BCM's security. The impact is major, as it enables unauthorized command injection. This failure mode is a critical security violation.

Attack Narrative

The attacker gains access to the TCU via the Telematics Server using a malicious SMS. The attacker then bridges vehicle networks at the Gateway to move laterally. This bridging allows the attacker to reach the BCM. The attacker then exploits the BCM to unlock the doors. This path highlights the risk of network bridging between different vehicle domains.

Damage Scenario

The BCM is compromised, allowing the attacker to control the door locking mechanism. This results in a loss of vehicle security and potential financial liability for the manufacturer. Fleet-wide exposure is high if the network bridging is not properly restricted.

Attack Tree [AND]: Bridge vehicle networks to reach the BCM

- [AND] Bridge vehicle networks at the Gateway to move laterally → High

Cybersecurity Requirements

- CSR-007: Implement strict firewall rules on the Gateway to prevent unauthorized bridging between vehicle networks.
- CSR-008: Use a secure gateway architecture that validates all cross-domain traffic.

Recommended Mitigations

- Implement strict firewall rules on the Gateway to prevent unauthorized bridging between vehicle networks.
- Use a secure gateway architecture that validates all cross-domain traffic.

Inferences Made

- (No CVEs in input for these assets)

Required Attack Equipment

- EQ BladeRF 2.0
- EQ Vector CANalyzer 17.0
- EQ Busmaster 3.2.2

FS-005 Gateway Remote Service Exploitation for Lateral Movement

Integrity | Feasibility: High (8) | Risk Level: High | Confidence: high

Function Category: Communication **Source Paths:** P25

Source Threats: Threat_24, Threat_115, Threat_109, Threat_153

Hardware: Gateway NXP S32K144 | **Software:** Gateway remote service firmware v2.0.1 | **Interfaces:** Ethernet, CAN-FD

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The Gateway's remote services are compromised, allowing the attacker to move laterally to the BCM. This operational failure compromises the BCM's security. The impact is major, as it enables unauthorized command injection. This failure mode is a critical security violation.

Attack Narrative

The attacker uses the Telematics Server to send a malicious SMS to the TCU. The attacker then exploits remote services on the Gateway to move laterally. This lateral movement leads to the BCM. The attacker then unlocks the doors by sending malicious commands to the BCM. This path exploits the inherent trust placed in remote services.

Damage Scenario

The BCM is compromised, allowing the attacker to control the door locking mechanism. This results in a loss of vehicle security and potential financial liability for the manufacturer. Fleet-wide exposure is high if the remote services are not properly secured.

Attack Tree [AND]: Exploit remote services on the Gateway to move laterally

- [AND] Exploit remote services on the Gateway to move laterally → High

Cybersecurity Requirements

- CSR-009: Harden remote services on the Gateway by implementing robust authentication and authorization.
- CSR-010: Regularly audit remote service configurations for vulnerabilities.

Recommended Mitigations

- Harden remote services on the Gateway by implementing robust authentication and authorization.
- Regularly audit remote service configurations for vulnerabilities.

Inferences Made

- (No CVEs in input for these assets)

Required Attack Equipment

- EQ HackRF One
- EQ Vector CANalyzer 17.0
- EQ Wireshark 4.0

FS-006 BCM Immobilizer Deactivation via Gateway Privilege Escalation

Availability | Feasibility: Low (16) | Risk Level: High | Confidence: high

Function Category: Access Control **Source Paths:** P41

Source Threats: Threat_24, Threat_62, Threat_109, Threat_165

Hardware: Gateway NXP S32K144 | **Software:** Gateway elevation control firmware v2.1.0 | **Interfaces:** CAN-FD, UDS

Safety	Financial	Operational	Privacy
Severe	Severe	Severe	Moderate

Functional Impact

The immobilizer function is deactivated, allowing the engine to start without a valid key. This operational failure leads to the complete loss of the vehicle. The impact is severe, as it directly enables vehicle theft. This failure mode is a critical safety and security violation.

Attack Narrative

The attacker uses the Telematics Server to deliver a malicious SMS to the TCU. The attacker then abuses the elevation control mechanism on the Gateway. This privilege escalation allows the attacker to move laterally to the BCM. The attacker then steals the vehicle by manipulating the BCM. This path is effective because it bypasses security controls through privilege escalation.

Damage Scenario

The vehicle is stolen, resulting in a total financial loss for the owner. The manufacturer faces significant reputational damage and potential legal liability. Fleet-wide vulnerability exists due to the lack of authentication on the BCM diagnostic interface.

Attack Tree [AND]: Deactivate immobilizer via privilege escalation on the Gateway

- [AND] Abuse elevation control mechanism on the Gateway to gain diagnostic access → Low

Cybersecurity Requirements

- CSR-011: Implement strict access control for elevation mechanisms on the Gateway.
- CSR-012: Use hardware-based security to protect sensitive elevation keys.

Recommended Mitigations

- Implement strict access control for elevation mechanisms on the Gateway.
- Use hardware-based security to protect sensitive elevation keys.

Inferences Made

- (No CVEs in input for these assets)

Required Attack Equipment

- EQ HackRF One
- EQ Vector CANalyzer 17.0
- EQ Saleae Logic Pro 16

FS-007 BCM Immobilizer Deactivation via Gateway Co-located Service Exploitation NOVEL FINDING

Availability | Feasibility: Low (18) | Risk Level: High | Confidence: high

Function Category: Access Control **Source Paths:** P45

Source Threats: Threat_24, Threat_63, Threat_109, Threat_165

Hardware: Gateway ARM Cortex-A7 | **Software:** Linux-based Gateway OS v3.0 | **Interfaces:** Ethernet, CAN-FD

Novel Attack Surface

Exploitation of co-located computing services on the Gateway for vehicle theft.

Safety	Financial	Operational	Privacy
Severe	Severe	Severe	Moderate

Functional Impact

The immobilizer function is deactivated, allowing the engine to start without a valid key. This operational failure leads to the complete loss of the vehicle. The impact is severe, as it directly enables vehicle theft. This failure mode is a critical safety and security violation.

Attack Narrative

The attacker uses the Telematics Server to compromise the TCU via a malicious SMS. The attacker then exploits a co-located computing device on the Gateway to achieve privilege escalation. This escalation facilitates lateral movement to the BCM. The attacker then steals the vehicle by manipulating the BCM. This path demonstrates the risk of co-located services.

Damage Scenario

The vehicle is stolen, resulting in a total financial loss for the owner. The manufacturer faces significant reputational damage and potential legal liability. Fleet-wide vulnerability exists due to the co-located services on the Gateway.

Attack Tree [AND]: Deactivate immobilizer via co-located service exploitation on the Gateway

- [AND] Exploit co-located computing device on the Gateway to achieve privilege escalation → Low

Cybersecurity Requirements

- CSR-013: Isolate co-located computing devices on the Gateway.
- CSR-014: Implement strict memory protection on the Gateway.

Recommended Mitigations

- Isolate co-located computing devices on the Gateway.
- Implement strict memory protection on the Gateway.

Inferences Made

- (No CVEs in input for these assets)

Required Attack Equipment

- EQ BladeRF 2.0
- EQ Vector CANalyzer 17.0
- EQ Busmaster 3.2.2

FS-008 BCM Immobilizer Deactivation via Gateway Network Bridging

Availability | Feasibility: High (7) | Risk Level: Critical | Confidence: high

Function Category: Access Control **Source Paths:** P53

Source Threats: Threat_24, Threat_108, Threat_109, Threat_165

Hardware: Gateway NXP S32K144 | **Software:** Gateway routing table firmware v1.0.5 | **Interfaces:** CAN-FD, Ethernet

Safety	Financial	Operational	Privacy
Severe	Severe	Severe	Moderate

Functional Impact

The immobilizer function is deactivated, allowing the engine to start without a valid key. This operational failure leads to the complete loss of the vehicle. The impact is severe, as it directly enables vehicle theft. This failure mode is a critical safety and security violation.

Attack Narrative

The attacker uses the Telematics Server to deliver a malicious SMS to the TCU. The attacker then bridges vehicle networks at the Gateway to move laterally. This bridging allows the attacker to reach the BCM. The attacker then steals the vehicle by manipulating the BCM. This path highlights the risk of network bridging.

Damage Scenario

The vehicle is stolen, resulting in a total financial loss for the owner. The manufacturer faces significant reputational damage and potential legal liability. Fleet-wide vulnerability exists due to the lack of network isolation.

Attack Tree [AND]: Deactivate immobilizer via network bridging on the Gateway

- [AND] Bridge vehicle networks at the Gateway to move laterally → High

Cybersecurity Requirements

- CSR-015: Implement strict firewall rules on the Gateway to prevent unauthorized bridging.
- CSR-016: Use a secure gateway architecture that validates all cross-domain traffic.

Recommended Mitigations

- Implement strict firewall rules on the Gateway to prevent unauthorized bridging.
- Use a secure gateway architecture that validates all cross-domain traffic.

Inferences Made

- (No CVEs in input for these assets)

Required Attack Equipment

- EQ HackRF One
- EQ Vector CANalyzer 17.0
- EQ Saleae Logic Pro 16

FS-009 BCM Immobilizer Deactivation via Gateway Remote Service Exploitation

Availability | Feasibility: High (8) | Risk Level: Critical | Confidence: high

Function Category: Access Control **Source Paths:** P57

Source Threats: Threat_24, Threat_115, Threat_109, Threat_165

Hardware: Gateway NXP S32K144 | **Software:** Gateway remote service firmware v2.0.1 | **Interfaces:** Ethernet, CAN-FD

Safety	Financial	Operational	Privacy
Severe	Severe	Severe	Moderate

Functional Impact

The immobilizer function is deactivated, allowing the engine to start without a valid key. This operational failure leads to the complete loss of the vehicle. The impact is severe, as it directly enables vehicle theft. This failure mode is a critical safety and security violation.

Attack Narrative

The attacker uses the Telematics Server to send a malicious SMS to the TCU. The attacker then exploits remote services on the Gateway to move laterally. This lateral movement leads to the BCM. The attacker then steals the vehicle by manipulating the BCM. This path exploits the trust placed in remote services.

Damage Scenario

The vehicle is stolen, resulting in a total financial loss for the owner. The manufacturer faces significant reputational damage and potential legal liability. Fleet-wide vulnerability exists due to the lack of remote service security.

Attack Tree [AND]: Deactivate immobilizer via remote service exploitation on the Gateway

- [AND] Exploit remote services on the Gateway to move laterally → High

Cybersecurity Requirements

- CSR-017: Harden remote services on the Gateway.
- CSR-018: Regularly audit remote service configurations.

Recommended Mitigations

- Harden remote services on the Gateway.
- Regularly audit remote service configurations.

Inferences Made

- (No CVEs in input for these assets)

Required Attack Equipment

- EQ BladeRF 2.0
- EQ Vector CANalyzer 17.0
- EQ Busmaster 3.2.2

FS-010 BCM Door Control via Gateway Network Service Scanning

Integrity | Feasibility: High (7) | Risk Level: High | Confidence: high

Function Category: Access Control **Source Paths:** P1

Source Threats: Threat_24, Threat_98, Threat_109, Threat_153

Hardware: Gateway NXP S32K144 | **Software:** Gateway network service firmware v1.0.0 | **Interfaces:** CAN-FD, Ethernet

Safety	Financial	Operational	Privacy
Major	Major	Major	Moderate

Functional Impact

The BCM door control function is compromised, allowing unauthorized unlocking of the vehicle. This operational failure bypasses all physical security measures, enabling unauthorized entry. The impact is major, as it directly facilitates vehicle theft and potential occupant harm. This failure mode violates ISO 26262 safety requirements for secure access control.

Attack Narrative

The attacker initiates the attack by sending a malicious SMS to the TCU via the Telematics Server. The attacker then performs network service scanning on the Gateway to identify reachable diagnostic services on the BCM. Once the BCM is identified, the attacker sends a series of UDS commands to unlock the doors. The BCM, lacking proper authentication for these commands, processes them and unlocks the doors. The attacker gains physical access to the vehicle.

Damage Scenario

The BCM is compromised, allowing the attacker to control the door locking mechanism. This results in a loss of vehicle security and potential financial liability for the manufacturer. Fleet-wide exposure is high if the network service scanning is not properly restricted.

Attack Tree [AND]: Unlock vehicle doors via network service scanning on the Gateway

- [AND] Perform network service scanning on the Gateway to identify BCM diagnostic endpoints → High

Cybersecurity Requirements

- CSR-019: Implement intrusion detection systems (IDS) on the Gateway to detect network service scanning.
- CSR-020: Use secure boot and firmware integrity checks on the BCM to prevent unauthorized modification.

Recommended Mitigations

- Implement intrusion detection systems (IDS) on the Gateway to detect network service scanning.
- Use secure boot and firmware integrity checks on the BCM to prevent unauthorized modification.

Inferences Made

- (No CVEs in input for these assets)

Required Attack Equipment

- EQ Rohde & Schwarz CMW500
- EQ Vector CANalyzer 17.0
- EQ Segger J-Link EDU

Cross-Scenario Insights

The analysis reveals that the lack of authentication on the BCM diagnostic interface is a systemic vulnerability across all scenarios. The Gateway is consistently targeted as a pivot point due to its role in bridging vehicle networks and its exposure to remote services. Priority remediation should focus on implementing SecOC on the CAN bus and hardening the Gateway's diagnostic and remote service interfaces.

Priority Mitigation Plan

Immediate actions include implementing rate-limiting on diagnostic requests and deploying IDS on the Gateway to detect scanning activities. Medium-term mitigations involve implementing SecOC on all BCM-bound CAN frames and isolating co-located computing services on the Gateway. Long-term monitoring requirements include continuous penetration testing and regular audits of remote service configurations.

Lifecycle Considerations

All identified vulnerabilities require urgent attention due to the high risk of remote exploitation and the potential for fleet-wide impact. Future vehicle designs must incorporate hardware-based security modules and strict network segmentation to mitigate these risks.

7. Attack Feasibility Rating

Mode: remote | Derived CAL: CAL4 | Impact Basis: Major

Threat ID	Threat Name	Feasibility	Risk Level	CAL	Risk Treatment Decision
Threat_108	Bridge Vehicle Networks	High	High	CAL4	Reduce and define cybersecurity goals
Threat_116	Remote services in In-Vehicle Network	High	High	CAL4	Reduce and define cybersecurity goals
Threat_109	Exploit ECU for Lateral Movement	High	High	CAL4	Reduce and define cybersecurity goals
Threat_98	Network Service Scanning	High	High	CAL4	Reduce and define cybersecurity goals
Threat_88	Network Sniffing	High	High	CAL4	Reduce and define cybersecurity goals
Threat_62	Abuse Elevation Control Mechanism	Low	Medium	CAL4	Reduce if feasible, otherwise retain with explicit rationale
Threat_63	Exploit Co-Located Computing Device for Privilege Escalation	High	High	CAL4	Reduce and define cybersecurity goals
Threat_40	External Remote Services	High	High	CAL4	Reduce and define cybersecurity goals
Threat_24	Malicious SMS	High	High	CAL4	Reduce and define cybersecurity goals
Threat_115	Exploitation of Remote Services in In-Vehicle Network	High	High	CAL4	Reduce and define cybersecurity goals

Threat ID	Threat Name	Feasibility	Risk Level	CAL	Risk Treatment Decision
Threat_153	Control Doors	High	High	CAL4	Reduce and define cybersecurity goals
Threat_165	Vehicle Theft	High	High	CAL4	Reduce and define cybersecurity goals

8. Risk Value Determination

Internal Rule: Risk level is derived from *maximum impact* and *attack feasibility*. The score is calculated as Impact(0-4) + Feasibility(0-4), then mapped to Low, Medium, High, or Critical.

- 0-2: Low
- 3-4: Medium
- 5-6: High
- 7-8: Critical

9. Risk Treatment Decision

For each identified threat scenario, the recommended treatment is shown in the table above. High or Critical risks should be reduced and traced to cybersecurity goals. Medium risks may be reduced or retained with an explicit rationale. Low risks may be retained with documented assumptions and monitoring.